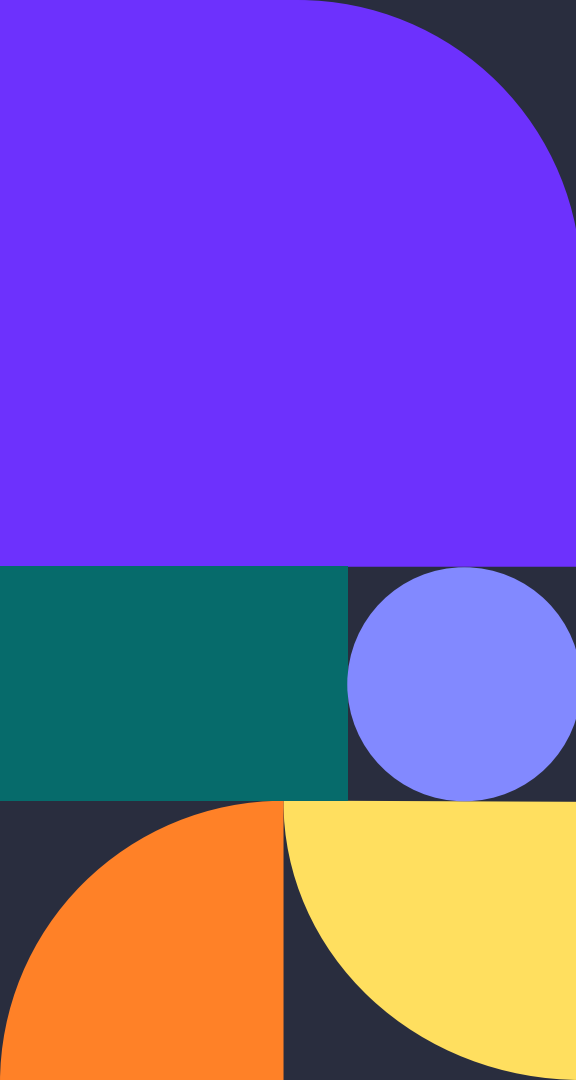




# Final Status Report:

## G9

Charles Aylmer, Aziz BinAbid, Jack Caugherty, Antonio Daiute, Ryan Jeuch,  
Prithvi Sudhakar



# BLUF

- USB inserted into Domain Controller and Workstations
- Phishing email leads to ransomware breach \$2.5 million demanded
- Sensitive data compromised of 1,463 individuals
- Attack occurred from Dec. 13-17
- Employee Beth Smith system compromised
- Attacker maintained remote access to systems
- Strong indication of lateral movement



# Reconnaissance:

- Passenger asked employee (Howard) multiple questions:
  - Passenger data
  - System functions
  - Screen visibility
- USB found at gate scanner
- Boarding data mismatch and scanner malfunction noticed at the same time
- Indicates environment probing, USB attack setup

**Mandatory incident reporting protocol for staff would have flagged this before digital access was achieved.**



# Delivery

- Email body was encrypted, consistent with antivirus evasion
- Delivered before Dec 14
- Opened by the victim; Valak malware active in memory by Day 2 snapshot
- Email to Trinity (WS01) contained zipped malware, found unzipped on desktop post attack

Email to Trinity with attached malware

## URGENT!!!

**From:** "Student Safety Team State College" <SCSD\_StudentSafety@mail.com>  
**To:** trinity.moss@mail.com  
**Date:** Dec 16, 2025 7:57:20 PM

---

Trinity,

This is an automated message from the State College School District.

Earlier today your child was transported from school to our local hospital due to a medical emergency. At this time, staff were unable to reach you because of technical difficulties on our end.

For privacy reasons, details cannot be shared at this moment without confirming your identity. Please review the incident report using the attached portal below immediately as this is an emergency. Please unzip the file using your first name:

Failure to confirm within 30 minutes may delay communication with medical staff.

State College School District  
Student Safety Team

---

## Attachments

- Portal.exe.zip

**Preventable with more scrutiny in email filters. ().exe.zip is a very suspicious attachment type**



# Exploitation

- Valak is a documented info-stealer and malware loader, known to arrive via encrypted email payloads
- Valak malware recovered from system memory on WS03 (Beth's machine)
- Already active by the Day 2 (pre-attack) snapshot, exploitation occurred before Dec 14
- HTA (HTML Application) files allow attackers to execute malicious scripts directly in memory
- Disguised web links leading to external websites found
- PowerShell launched scripts at least five times in a 27 minute-timespan

## POWERSHELL ACTIVITY

- All 42 PowerShell events originated from two machines on Dec 14 between 7:56 PM and 8:43 PM
- Rapid repeated sessions consistent with automated script execution, not a user typing commands manually
- Evidence of frequent remote activity observed

**Preventable by scanning attachments, filtering emails, blocking risky tools, and implementing endpoint protection**

# Installation

## Ransomware Deployed

- Ransomware script was placed on Beth Smith's desktop
- Potential remote access to external systems
- Information exfiltration

## Ransom Note Found

- Dropped to desktop; proof ransomware ran to completion

## Evidence Recovered

- Shortcut for ransomware software recovered
- New events and processes were logged between Dec 15–16

## Credentials Targeted

- Login Info file accessed, suggesting credential harvesting for lateral movement



# Command & Control

- Dec 16, 12:05–12:07 AM EST:
  - Spike in external internet traffic communicating with our server
- Attacker evaded detection
- Dec 16, 5:00–5:07 AM EST:
  - **Huge** spike in internet traffic with 99% of traffic going to one individual
  - Data exfiltration event
  - Symantec DLP





# Defense Evasion

14,427

AUDIT POLICY CHANGES  
in a single hour

Dec 15 - 12:00 AM  
Event ID 4907

## Why this matters

- Deliberate attempt to blind the monitoring system
- 14,427 changes within 60 minutes is not normal system behavior
- Affected machines: **WS01** (8,878 changes) and **desktop-qcge6f9** (5,614 changes), the two most active machines during the attack window
- Process creation logging (Event 4688) was likely disabled as a result, explaining why Ransomware.py execution does not appear in the logs

## Self Deletion

- Ransomware.py was deleted from the filesystem after execution, only a shortcut file (.lnk) remains as evidence it existed.
- My\_Login\_Info.txt and the phishing email body were both encrypted post-attack, covering the attacker's tracks.

Preventable with an automated alerting on audit policy changes would have flagged this in real time, hours before exfiltration occurred.





# Actions on Objectives

## Ransom Demand

- Payment demanded in Bitcoin within 72 hours
- Contact: youwillneverfindus@protonmail.com
- Reference: WESTGATE-PAYMENT-WG20241203
- Threat: public release of all exfiltrated data if unpaid

## Compromised Data

- Employee SSNs: sample provided by attacker as proof
- TSA screening protocols and security procedures
- Passenger manifests and personal information
- HR records, background checks, payroll data
- Financial records and banking information
- Building access credentials

| Employee      | Last 4 SSN  | Employee     | Last 4 SSN  |
|---------------|-------------|--------------|-------------|
| Howard Ratner | ***-**-7281 | Beth Smith   | ***-**-8847 |
| Yan Naing Lee | ***-**-4729 | Trinity Moss | ***-**-2910 |

Offline encrypted backups and network segmentation would have limited impact



# Remediation & Recovery

- Immediate containment of impacted systems
- Use pre-attack system images
- Trigger TSA, CISA, and FAA notifications
- Eradicate infection
- Restore operations in priority order
- Validate systems before returning to full operation



# Legal Implications

## Federal

- Federal Aviation Administration (FAA) for infrastructure impacts
  - Federal Aviation Act (49 U. S. C. §§ 40.101)
- Transportation Security Administration (TSA) for passenger data
  - Aviation and Transportation Security Act (ATSA) of 2001 (49 U.S.C. § 114)
- Cybersecurity & Infrastructure Security Agency (CISA) for federal response
  - Cyber Incident Reporting for Critical Infrastructure Act (CIRCIA) of 2022 (6 U.S.C. § 681-681g)
  - Cybersecurity Information Sharing Act (CISA 2015, 6 U.S.C. §§ 1501-1510)
- Federal Bureau of Investigation (FBI) for criminal investigation and cybercrime law enforcement
  - Computer Fraud and Abuse Act (CFAA), 18 U.S.C. § 1030

## State

- Pennsylvania Breach of Personal Information Notification Act (73 P.S. § 2301 et seq.)
  - Affected individuals notification within seven days
  - Attorney General reporting (more than 500 impacted)
  - Mandatory credit monitoring
  - Non-PA residents may need additional notification
- Pennsylvania Criminal Statutes (18 Pa. C.S. § 7611)

## Others

- Airport vendors' contractual liability



# References

Cybersecurity and Infrastructure Security Agency. (2023). Cyber incident reporting resources.

<https://www.cisa.gov/>

Federal Trade Commission. (n.d.). Identity theft. <https://www.identitytheft.gov/>

Pennsylvania General Assembly. (2005). Breach of Personal Information Notification Act, 73 P.S. §§ 2301-2329.

<https://www.legis.state.pa.us/WU01/LI/LI/US/HTM/2005/0/0094..HTM>

Transportation Security Administration. (2022, October 7). TSA announces new cybersecurity requirements for airport and aircraft operators.

<https://www.tsa.gov/news/press/releases/2022/10/07/tsa-announces-new-cybersecurity-requirements-airport-and-aircraft>

United States District Court for the Eastern District of Pennsylvania. (n.d.). Redaction requirements and sealed documents.

<https://www.paed.uscourts.gov/redaction-requirements-and-sealed-documents>

U.S. Department of Transportation. (n.d.). Air consumer privacy.

<https://www.transportation.gov/individuals/aviation-consumer-protection/privacy>

**Thank you**